

# Scoping a Penetration Test

Scoping, Rules of Engagement, Environmental Scope, In/Out-of-Scope Assets & Scope Validation

**Prepared for:** Muhammad Shafiq Goraya

**Track:** Red Team / Penetration Testing

**Style:** Plain explanations, real-world examples, no quiz format

**Covers:** Lesson 1 (Scoping fundamentals) through Lesson 5 (Scope Validation) — the complete scoping foundation for CompTIA PenTest+, CTFs, and bug bounty

Scoping

Rules of Engagement

Environmental Scope

In-Scope Assets

Out-of-Scope Assets

Target List

Scope Validation

## WHAT'S INSIDE

- Lesson 1 — What is Scoping? (Foundation)
- Lesson 2 — Rules of Engagement (ROE)
- Lesson 3 — Environmental Scope
- Lesson 4 — In-Scope and Out-of-Scope Assets
- Lesson 5 — Scope Validation
- Lecture Summary + Memory Trick

## Lesson 1 · What is Scoping?

### Foundation Note

This lecture's opening portion wasn't included in the pasted material, but scoping is the natural starting point for everything that follows, so here is the foundational explanation before we continue into Rules of Engagement, Environmental Scope, In/Out-of-Scope Assets, and Scope Validation.

### Simple Meaning

Scoping is the process of clearly defining what will be tested, what will not be tested, and under what conditions a penetration test will happen — before any hacking activity begins.

### Easy Example

Imagine hiring a home inspector. Before they start, you agree: "Inspect the main house, not the neighbor's garage. Inspect between 9 AM and 5 PM. Do not open locked cabinets." That agreement is scoping. Penetration testing works the same way — the client and the tester must agree on exactly what is being tested, and under what rules, before the first scan ever runs.

### Why Scoping Comes First

Without scoping, a tester might accidentally test systems the client never authorized, work outside agreed hours, or use tools the client didn't approve. Scoping prevents all of this by turning a vague agreement ("test our security") into a precise, documented plan.

### Key Idea

Scoping answers four essential questions: What environment are we testing? Which specific assets are included? Which are excluded? And what rules must we follow throughout?

## Lesson 2 · Rules of Engagement (ROE)

### Full Form

ROE = Rules of Engagement

### What is the ROE?

The ROE is the rulebook of the penetration test. It tells the pentester what is allowed, what is not allowed, when testing is allowed, and any special restrictions that apply during the engagement.

### Example for Understanding

Think of the ROE like the rules given to a referee before a football match — which fouls are allowed to be called, what time the match starts and ends, and what special conditions apply that day. Without these rules being set clearly in advance, the match (or in this case, the penetration test) could become chaotic or unfair to either side.

## What the ROE Typically Covers

- What actions and techniques are permitted
- What actions and techniques are forbidden
- The allowed testing window (dates and times)
- Any special restrictions (e.g., no DoS attacks, no phishing employees)

### Key Idea

The ROE is the rulebook. Environmental Scope and the Target List (covered in the next lessons) tell you where those rules apply.

## Lesson 3 · Environmental Scope

### What is Environmental Scope?

Environmental Scope tells us what type of environment we are testing. Different environments require completely different penetration testing methods.

#### Network Assessment

Suppose the client says: "Test our company network." Now the focus is on routers, switches, servers, and firewalls — the tools and techniques all center around the network layer.

#### Wireless Assessment

Suppose the client says: "Test our Wi-Fi." Now the work changes completely — Wi-Fi security, WPA2/WPA3 encryption, rogue access points, and weak wireless passwords become the focus. This is very different from testing routers and web servers.

#### Web Application Assessment

Suppose the client says: "Test our shopping website." Now the focus shifts to SQL Injection, Cross-Site Scripting (XSS), authentication, session management, and file upload vulnerabilities — completely different skills than wireless testing.

#### Cloud Assessment

Suppose the client uses AWS or Azure. The scope may say: test the S3 bucket, the EC2 server, and the API Gateway, but do NOT test the entire cloud account or other cloud resources. Only the listed cloud resources are in scope.

### Why Environmental Scope Matters

Every environment is different, so the scope must clearly define which environment is being tested. If the scope says "test the web application" and you start attacking the Wi-Fi instead, you are outside the scope — even if your intentions were good.

### Real Bug Bounty Example

On platforms like HackerOne or Bugcrowd, programs clearly list what's in scope, for example `api.company.com` and `app.company.com`, and what's out of scope, such as the employee email system, the physical office, and third-party services. Professional bug bounty hunters always read the scope first before testing.

### Senior Pentester Tip

Before starting any engagement, ask yourself: What environment am I testing? What systems are included? What systems are excluded? If these answers are not clear, don't begin testing — clarify the scope with the client first.

## Quick Notes

Environmental Scope defines: Network, Wireless, Web Application, Cloud, and Internal or External systems. Each environment needs different tools and techniques.

## Lesson 4 · In-Scope and Out-of-Scope Assets

This is one of the most important topics for CTFs, Bug Bounty, PenTest+, and real penetration testing.

### What is an Asset?

An asset is anything you are allowed to test — for example a website, an API, a server, a database, a mobile app, an IP address, or a domain name.

### In-Scope Assets

In-Scope means you have permission to test these specific targets. For example, the client may give you this list:

#### Example Target List

`api.company.com`, `shop.company.com`, `192.168.10.20`, `192.168.10.30`

These are your targets. You are allowed to scan them, find vulnerabilities, and exploit vulnerabilities if the scope allows it.

### Out-of-Scope Assets

Suppose you discover `mail.company.com` or `vpn.company.com`, but these are not listed in the scope. Even if they have serious vulnerabilities, you must not test them. Professional penetration testers clearly define both what is in scope and what is out of scope before testing begins.

### Real Bug Bounty Example

A bug bounty program lists `app.company.com` and `api.company.com` as in scope, while `mail.company.com`, `careers.company.com`, and third-party services are out of scope. If you find a SQL Injection on `mail.company.com`, you should not report it as a bounty submission, because you tested a target that was outside the agreed scope.

## Why the Target List Matters

The scope document contains a Target List that answers questions like: which domains, which IP addresses, which APIs, internal or external systems, and physical locations if applicable. This gives the pentester a clear roadmap.

### Senior Pentester Tip

Before running Nmap, Burp Suite, or Gobuster, always ask: "Is this target in scope?" If the answer is No, don't touch it. That simple habit protects your professionalism and keeps the engagement legal.

## Quick Notes

| Term         | Meaning                                   |
|--------------|-------------------------------------------|
| Asset        | A system, website, API, server, or device |
| In Scope     | Allowed to test                           |
| Out of Scope | Not allowed to test                       |
| Target List  | Official list of assets you can test      |

### Interview Tip

If asked: "What do you do if you discover a vulnerable system that is outside the agreed scope?" — the professional answer is: "I do not test or exploit it. I document the observation if appropriate and inform the client or program owner according to the engagement rules, but I stay within the agreed scope."

## Lesson 5 · Scope Validation

### What is Scope Validation?

Scope Validation means making sure both the client and the penetration testing team agree on exactly what will be tested before the assessment starts. Simply put: double-check everything before you begin.

### Why Scope Validation is Needed

#### The Misunderstanding Problem

Imagine the client thinks the agreement covers testing the website and the API. But the pentester thinks it also includes testing the Wi-Fi. If the pentester attacks the Wi-Fi, the client may complain because it was never approved. That is why, before testing starts, both sides review the scope together.

### How Scope is Validated — Step by Step

#### Step 1 — Ask Questions

The pentester asks the client questions such as: What are your biggest security concerns? Which systems should we test? Which systems should we avoid?

### Step 2 — Create the Scope Document

Using the client's answers, the pentester prepares a scope document including the Rules of Engagement, target list, in-scope assets, out-of-scope assets, testing schedule, and allowed and disallowed tests.

### Step 3 — Review Together

Both the client and the penetration testing team carefully read the document, checking that the IP addresses are correct, the domains are correct, the schedule is correct, and the restrictions are correct.

### Step 4 — Approval

When everyone agrees, the client signs it, and the penetration testing company signs it. Now the engagement officially begins.

#### Real Example

Suppose the document says: In Scope — app.company.com and api.company.com. Testing Time — 8 PM to 5 AM. Not Allowed — DoS attacks and employee phishing. Both sides review it, everything looks correct, everyone signs, and now the pentester starts testing.

## Handling Mid-Engagement Changes

If the client wants changes, the scope document should be updated before testing outside the original agreement. Until those changes are officially approved, the pentester must stay within the existing scope.

#### Senior Pentester Tip

Never think "I'll test one extra server, it won't matter." That is not professional. Instead: stop, contact the client, update the scope if necessary, get approval, then continue testing. This protects both you and the client.

## Memory Trick — The Full Scoping Sequence

Client Requirements

Ask Questions

Create Scope

Review Together

Validate

Sign

## Lecture Summary · What You Should Now Know

- What Scoping is
- What Rules of Engagement (ROE) are
- What Environmental Scope means
- The difference between In-Scope and Out-of-Scope assets
- How to Validate the Scope before testing

These are fundamental concepts that every professional pentester follows — whether working a real client engagement, competing in a CTF, or hunting bugs on a bounty platform.

### The Full Keyword List

Scoping

ROE

Environmental Scope

Asset

In-Scope

Out-of-Scope

Target List

Scope Validation

Signed Approval

### Homework (10 minutes)

Without looking at your notes, explain these five topics in simple English, in your own words:

- Why scoping must happen before any testing begins
- The difference between the ROE and Environmental Scope
- Why testing an out-of-scope asset is a problem, even if it has a serious vulnerability
- The four steps of Scope Validation
- What to do if a client asks for extra testing that isn't in the current scope

If you can teach these five topics to someone else in simple English, you have truly understood them. Get some rest — you've earned it.